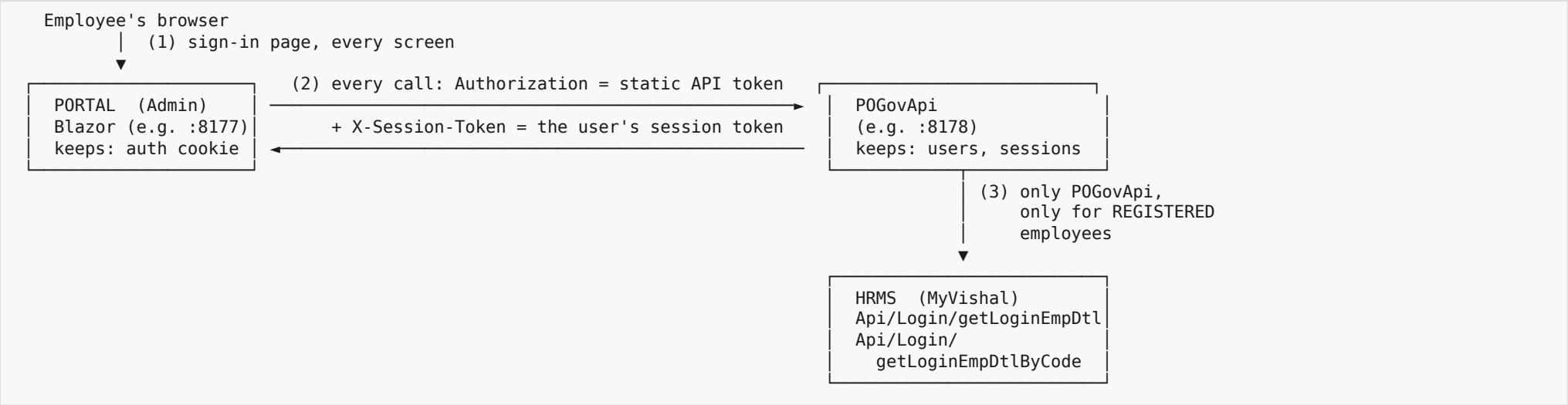
PO Governance — How sign-in works (login flow)

For: administrators, IT support and developers. **Applies to:** the portal (Admin) and POGovApi on this branch.

This document follows one employee from the moment the administrator registers them, through signing in and working, until they are signed out. Every step names who does what and where in the code it happens.

---

1. The parts and who talks to whom



Five rules to remember:

1. **The portal never calls HRMS.** It talks only to POGovApi. The HRMS URL and credentials are API_MASTER rows with `Api_Scope = SERVER`, and the portal never receives them.
2. **Only registered employees can sign in.** POGovApi first looks the Employee ID up among the logins the admin registered. If the ID is not there, **HRMS is not called at all** and the answer is "Employee ID or password is incorrect".
3. **The password is checked by HRMS.** PO Governance stores no password for employees.
4. **Signing in never creates or changes a user.** Only the administrator adds users, by fetching them from HRMS.
5. **One session per user.** Signing in on a second device ends the first session.

Where the data lives	What
POGovApi database, document `users`	One entry per login: email (the key), **Employee ID** (`empCode`), name, roles, active, the HRMS details fetched by the admin, failed-attempt count, lock time
POGovApi database, document `sessions`	One entry per session token: user, created, last seen, IP. An **ended** session keeps its reason for 24 hours (`replaced`, `changed`, `disabled`, `password`, `idle`, `expired`).
Portal auth cookie `pogov_auth`	The session token, the roles, the sign-in time, the idle minutes. HttpOnly, SameSite=Strict.
API_MASTER / API_BASE_URL	HRMS URL (`HRMS_API` + `Api/Login/...`), task names `HRP_GET_EMP_LOGIN_API` and `HRP_GET_EMP_DETAIL_CODE` (POGovApi `appsettings.json` → `HrmsApiNames`)

2. Before anyone can sign in (one-time set-up)

#	Who	What	Where
1	DBA	Run `database/sqlserver/04_api_master.sql`. It creates the two HRMS rows (paths `Api/Login/getLoginEmpDtl` and `Api/Login/getLoginEmpDtlByCode`) and the `HRMS_API` base URL, inactive.	SQL Server
2	DBA	Set the HRMS host of each environment and activate it: `UPDATE dbo.API_BASE_URL SET Base_Url = N'https://<hrms host>/', Active_Status = 1 WHERE Base_Url_Key = N'HRMS_API' AND Environment = N'Production'`. Copy the HRMS token or proxy from the QPS rows, if any.	SQL Server
3	IT	`POGovApi/appsettings.json` → `PoGovSettings`: `LoginMode = "Hrms"`, `AdminEmail` (the built-in admin), optionally `AdminEmpCode`.	POGovApi
4	Admin	First sign-in **with email** (the built-in admin, while `AllowAdminLocalLogin = true`). The first time, the default password 1234 must be changed.	Portal

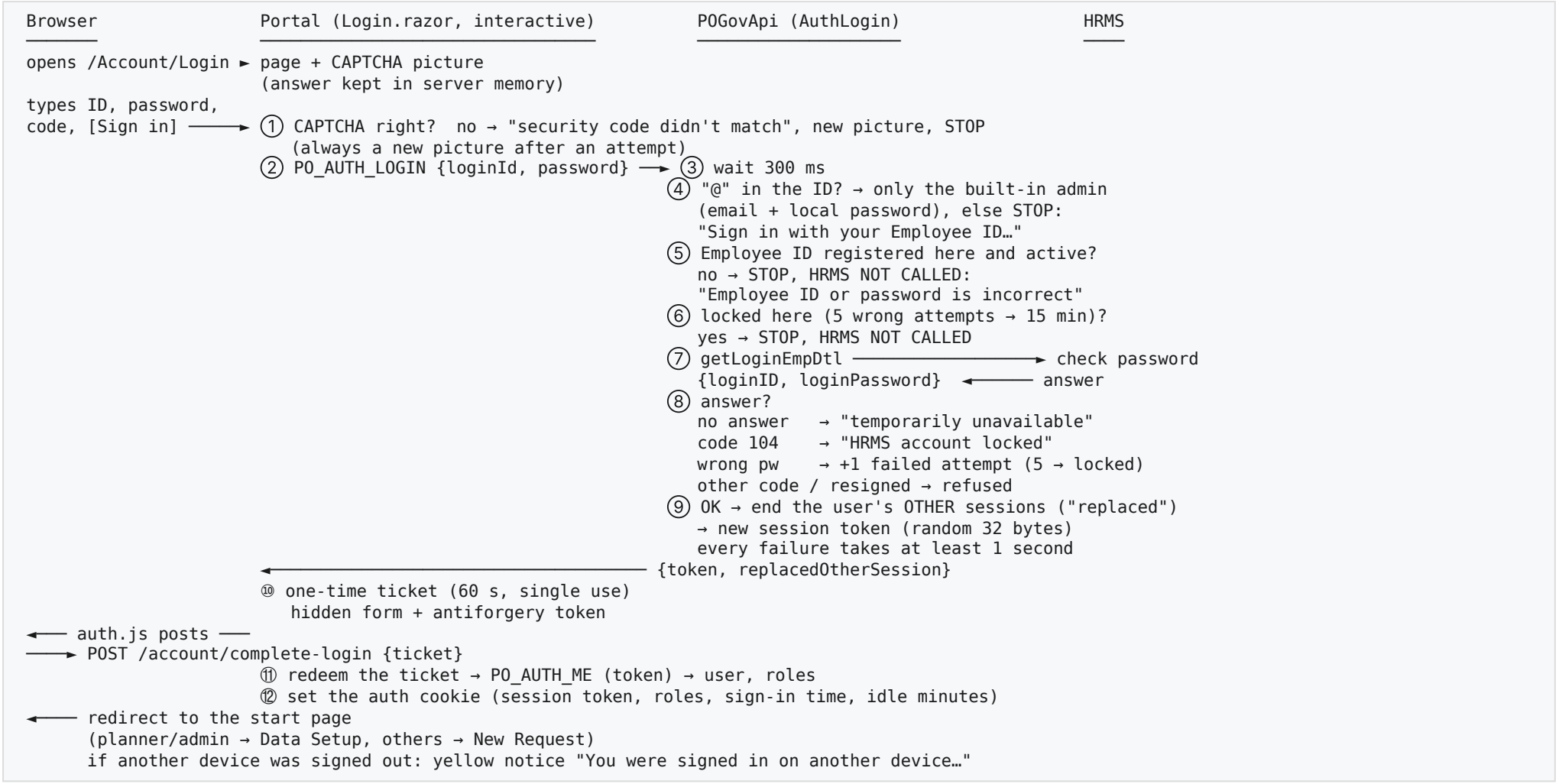
Until step 2 is done, employees see "Sign-in is temporarily unavailable (HRMS did not answer)", and **Fetch from HRMS** says "HRMS did not answer".

3. Flow A — the administrator registers an employee



- **Bulk add:** one `Employee ID, role` per line. Each ID is fetched from HRMS the same way.
- **Logins from the SCR file** are created by email without an Employee ID. They show ⚠ **Employee ID needed** and **cannot sign in** until the admin links them: Edit → Employee ID → Fetch from HRMS → **Link to this employee**. Adding the same employee with **+ Add user** also links the login and keeps its roles.
- **Code:** `POGovApi/Controllers/V1/AdminControllers.cs` (`UserHrmsLookup`, `UserAdd`, `UserLinkEmployee`), `Application/Services/V1/Platform/AccountsService.cs` (`LookupEmployeeAsync`, `AddEmployeeAsync`, `LinkEmployeeAsync`), `Infrastructure/Services/V1/HrmsApiClient.cs`.

4. Flow B — the employee signs in



Why the ticket? An interactive Blazor page cannot set a cookie; only an HTTP response can. The page therefore hands a one-time ticket, never the password, to `/account/complete-login`, which sets the cookie. There is **no endpoint that takes a password** (the old `/Account/SignIn` is gone), so the CAPTCHA cannot be skipped.

Code: `Admin/Components/Pages/Account/Login.razor`; `Admin/Auth/PortalAuthService.cs` (`VerifyAsync`, `CompleteSignInAsync`); `Admin/Auth/AccountEndpoints.cs` (`/account/complete-login`); `Admin/Auth/Captcha/*`; `POGovApi/Controllers/V1/AuthController.cs` (`AuthLogin`); `AccountsService.LoginAsync` → `EmployeeLoginAsync`.

What each check protects against

Step	Protects against
① CAPTCHA (single use, 5 min)	Automated password guessing
⑤ Registered and active first, before HRMS	**The QPS loophole**: any HRMS employee trying to get in
⑥ Local lock before HRMS	Guessing that would lock the person out of HRMS (MyVishal) as well
⑧ Same Employee ID in HRMS's answer, active, not resigned	A wrong or stale HRMS answer, and people who have left
③ + "at least 1 s"	Telling registered IDs from unknown ones by response time
⑨ Other sessions ended	Two devices at once (a shared or stolen login)
⑩–⑫ Ticket + antiforgery	Login CSRF (another site signing you in as someone else)

5. Flow C — while the employee works

```
Every screen action ──► portal ──► POGovApi call with X-Session-Token
                                    POGovApi checks the session on EVERY call:
                                      session ended? (replaced / changed / disabled / password) → 401 + reason
                                      idle > 30 min? → ends it ("idle") → 401
                                      older than 12 h? → ends it ("expired") → 401
                                      user deactivated? → 401 ("disabled")

Every HTTP request with the cookie ──► CookieValidator (portal)
    sign-in time > 12 h → refuse;  session in the "ended" list → refuse at once;
    at most every 60 s: PO_AUTH_ME → ended? → refuse cookie → sign-in page with ?reason=…

Open page (no HTTP requests) ──► ApiRevalidatingAuthStateProvider every 60 s:
    idle in this page ≥ 30 min → end;  PO_AUTH_ME → ended? → page signs out with the reason

Browser (idle-timeout.js) ──► mouse / keys / scroll in ANY portal tab = activity
    → tells the page (every 15 s at most)
    → POST /account/keepalive (every 5 min at most): renews the cookie and the API session
IdleTimeoutMonitor ──► 29 min idle: box "Session about to expire … 60 seconds" [Stay signed in] [Sign out]
                       30 min idle: signs out ("idle")
```

A short POGovApi outage does not sign people out. Failed checks are tolerated 5 times in a row (about 5 minutes) before the page gives up.

6. How a session ends

Reason	What caused it	Who notices	Message on the sign-in page
`signedout`	User → menu → ⏻ **Sign out**	–	"You have been signed out."
`idle`	30 minutes without activity	the page (with a warning first), or POGovApi	"You were signed out after a period of inactivity."
`replaced`	The same user signed in on another device	next check (≤ 60 s)	"You were signed out because your account was signed in on another device."
`changed`	Admin changed the roles, an SCR upload added roles, or an Employee ID was linked	next check (≤ 60 s)	"Your access was changed by the administrator. Please sign in again."
`disabled`	Admin deactivated or deleted the user	next check (≤ 60 s)	"Your account has been deactivated. Contact the administrator."
`password`	Password reset by the admin, or changed on another device (built-in admin only)	next check (≤ 60 s)	"Your password was changed. Sign in with the new password."
`expired`	12 hours since sign-in, or the session is unknown	next request / check	"Your session has ended. Please sign in again."

Sign-out mechanics: a POST with an antiforgery token to `/account/sign-out`. It ends the API session (`PO_AUTH_LOGOUT`), clears the cookie and adds the token to the "ended" list, so a copied cookie stops working at once. Then it redirects to `/Account/Login?reason=…`.

7. Special cases

Case	What happens
Built-in admin (`PoGovSettings:AdminEmail`)	Signs in with **email + local password** while `AllowAdminLocalLogin = true`, for the first set-up and HRMS outages. With `AdminEmpCode` set, it is registered as an HRMS login at start-up; then switch `AllowAdminLocalLogin` off.
Employee types their **email**	Refused: "Sign in with your Employee ID and HRMS password." HRMS is not called.
Not registered (valid HRMS account)	Refused: "Employee ID or password is incorrect". HRMS is not called; the audit log shows `login-fail … not a registered employee`.
Deactivated in PO Governance	Refused the same way; HRMS is not called.
Resigned / inactive in HRMS	Refused after HRMS answers: "Your HRMS record is not active."
Locked here (5 wrong passwords)	"Too many wrong attempts…" for 15 minutes; the admin can **Unlock** earlier. HRMS is not called while locked.
Locked in HRMS (HRMS code 104)	"Your HRMS account is locked…" — unlock in MyVishal (My Page → Unlock User) or wait.
HRMS down or not configured	"Sign-in is temporarily unavailable (HRMS did not answer)." Not counted as a wrong attempt.
Forgot password	MyVishal (link on the sign-in page). The admin cannot reset an employee's password.

Case	What happens
LoginMode = Local (machines without HRMS)	Email + password kept by the tool (v1.1.4 behaviour); the sign-in page asks for the email.

8. "I can't sign in" — checklist

Symptom	Check
"Employee ID or password is incorrect" with the right password	Users → is the Employee ID registered and **Active**? An SCR login with ⚠ **Employee ID needed** must be linked first. Audit log: `login-fail … not a registered employee`.
"Sign-in is temporarily unavailable (HRMS did not answer)"	`API_BASE_URL` row `HRMS_API` of **this environment** active with the real host? Paths `Api/Login/getLoginEmpDtl` / `…ByCode`? Can the POGovApi server reach HRMS (firewall / proxy)? POGovApi log: `HRMS API … failed / not configured`.
"Sign in with your Employee ID and HRMS password."	An email was typed. Use the Employee ID.
"The security code didn't match…"	Type the characters of the new picture (not case-sensitive).
Signed out every few minutes	Another device or browser is signing in with the same ID (`replaced`), or the admin keeps changing the user.
Signed out after 30 minutes	Idle time-out (`PoGovSettings:IdleTimeoutMinutes` / `PortalSettings:IdleTimeoutMinutes`).
Admin can't Fetch from HRMS	Same HRMS checks as above; the call is POGovApi → HRMS `getLoginEmpDtlByCode`.

Audit log (Users → 📜 Audit log): `login` (with `hrms emp=…`), `login-fail` with the reason, `login-error` (HRMS unavailable), `locked`, `user-add`, `user-link-hrms`, `logout`.

9. Settings that shape the flow

File → section	Setting	Default	Effect
POGovApi `PoGovSettings`	`LoginMode`	`Hrms`	`Hrms` = Employee ID + HRMS; `Local` = email + local password
	`AllowAdminLocalLogin` / `AdminEmail` / `AdminEmpCode`	true / – / empty	Built-in admin (section 7)
	`SingleSession`	true	One device at a time
	`IdleTimeoutMinutes` / `AbsoluteSessionHours`	30 / 12	Session idle / maximum life
	`MaxFailedLogins` / `LockoutMinutes`	5 / 15	Local lock
	`LoginFailureMinMs`	1000	Minimum time of a failed sign-in

File → section	Setting	Default	Effect
	`HrmsPasswordUrl`	MyVishal	"Forgot password?" link
POGovApi `HrmsApiNames`	`HRP_GET_EMP_LOGIN_API`, `HRP_GET_EMP_DETAIL_CODE`	same names	API_MASTER task names of the two HRMS calls
Portal `PortalSettings`	`IdleTimeoutMinutes` / `AbsoluteLifetimeHours`	30 / 12	Cookie life; keep equal to POGovApi's
	`Captcha`	VmmCaptcha, 5 characters	CAPTCHA picture (VmmCaptcha.dll on Windows, built-in elsewhere)
Portal `AppConfigurationSettings`	`UserRevalidateInSeconds`	60	How quickly a forced sign-out is noticed

10. Where the code is

Step	Portal (Admin)	POGovApi / Application
Sign-in page, CAPTCHA	`Components/Pages/Account/Login.razor`, `Components/Account/CaptchaField.razor`, `Auth/Captcha/*`	–
Credentials	`Auth/PortalAuthService.VerifyAsync`	`Controllers/V1/AuthController.AuthLogin` → `AccountsService.LoginAsync`
HRMS call	–	`Infrastructure/Services/V1/HrmsApiClient.cs`
Cookie	`Auth/AccountEndpoints` (`/account/complete-login`), `Auth/LoginTicketStore` (in `SessionSecurity.cs`)	–
Checks while working	`Auth/CookieValidator.cs`, `Auth/ApiRevalidatingAuthStateProvider.cs`	`Infrastructure/Authentication/SessionTokenAuthenticationHandler.cs` → `AccountsService.SessionAsync`
Idle	`Components/Account/IdleTimeoutMonitor.razor`, `wwwroot/js/idle-timeout.js`, `/account/keepalive`	`AccountsService.SessionAsync` (idle / 12 h)
Sign-out	`Components/Account/LogoutForm.razor`, `/account/sign-out`	`AuthLogout` → `AccountsService.LogoutAsync`
Users, registration	`Components/Shared/Platform/UsersTab.razor`	`AdminControllers` (`UserHrmsLookup`, `UserAdd`, `UserLinkEmployee`)

More detail: `docs/security/HRMS-Login.md` (design, QPS comparison, set-up).